

SOC THREAT DETECTION & INCIDENT INVESTIGATION LAB

Practical Portfolio Project using Kali Linux + Windows + Sysmon + Splunk

Target: SOC L1 / Junior SOC Analyst / IT Security roles

Workflow: Simulate → Detect → Triage → Investigate → Classify → Document

Safety: Perform security testing only against systems you own or are explicitly authorized to test.

1. Project Overview

This project demonstrates a realistic SOC workflow using a Windows endpoint, Sysmon telemetry, Kali Linux as a controlled testing machine, and Splunk as the SIEM. The objective is to show the complete analyst workflow from detection through investigation and incident classification.

Project outcomes:

- Detect port scanning and suspicious network activity
- Detect repeated Windows authentication failures
- Correlate failed logins with a later successful login
- Detect suspicious PowerShell/process activity
- Investigate source, destination, ports, users, processes and timelines
- Create Splunk searches/correlation rules and document findings
- Practice L1 triage and understand when escalation to L2 is appropriate

2. Lab Architecture

Kali Linux acts as the controlled testing machine. Windows is the monitored endpoint. Sysmon and Windows Event Logs provide telemetry, while Splunk indexes and searches those events.

```
Kali Linux
|
| controlled test traffic
v
Windows Endpoint
|
+-- Sysmon
+-- Windows Security/System Logs
|
v
Splunk SIEM
|
+-- Detection searches
+-- Correlation searches
+-- Alerts / Notable Events
+-- Incident investigation
```

3. Step 1 — Verify Network Connectivity

On Windows, open Command Prompt and identify the IPv4 address:

```
ipconfig
```

On Kali, identify its address:

```
ip addr
```

Test connectivity in both directions:

```
ping <WINDOWS-IP>
ping <KALI-IP>
```

Expected result: the systems should communicate if your lab network permits it.

4. Step 2 — Verify Sysmon

On Windows, run PowerShell as Administrator:

```
Get-Service Sysmon*
```

Confirm the Sysmon service is running. In Event Viewer check: Applications and Services Logs → Microsoft → Windows → Sysmon → Operational.

Useful Sysmon events:

Event ID	Meaning	SOC use
1	Process Creation	Investigate suspicious executables/PowerShell
3	Network Connection	Investigate network connections
11	File Creation	Investigate suspicious file activity

5. Step 3 — Verify Splunk Data

Start in Search & Reporting and identify your Sysmon sourcetype. Your exact index and sourcetype depend on your setup.

```
index=* "Sysmon"
| stats count by sourcetype
```

Test process creation events:

```
index=* EventCode=1
| stats count by Image
| sort -count
```

If these searches return no results, troubleshoot the Windows-to-Splunk input before building detections.

6. Detection #1 — Port Scan

Generate a controlled scan only against your own Windows lab endpoint from Kali:

```
nmap -sS <WINDOWS-IP>
```

In Splunk, first inspect Sysmon network events:

```
index=* EventCode=3
```

Then identify the actual field names in your data. Common fields may include source/destination IP and destination port.

```
index=* EventCode=3
| stats count by src_ip, dest_ip, dest_port
| sort -count
```

If those fields do not exist, inspect a raw event and use the field names present in your environment.

7. Port-Scan Detection Logic

A useful L1 detection is a single source communicating with many destination ports on one destination within a short time window. Treat the threshold as a lab starting point and tune it after observing normal traffic.

```
index=* EventCode=3
| bin _time span=5m
| stats dc(dest_port) as unique_ports count as connections by _time src_ip dest_ip
| where unique_ports >= 20
| sort -unique_ports
```

8. L1 Investigation — Port Scan

- Confirm source and destination belong to the lab.
- Check unique destination ports and total connections.
- Review first and last event times.
- Look for related processes in Sysmon Event ID 1.

- Check whether traffic was allowed or blocked.
- Determine whether activity is authorized testing, benign scanning, or suspicious.
- Record evidence and escalate according to the playbook when appropriate.

For your own Nmap test, the correct final classification is **Benign / Authorized Security Testing**. The same behavior against an unknown production endpoint could require a security investigation.

9. Detection #2 — Windows Failed Logins

Windows Security Event ID 4625 represents a failed logon. Start by finding the volume:

```
index=* EventCode=4625
| stats count by Account_Name, src_ip
| sort -count
```

A simple lab threshold search is:

```
index=* EventCode=4625
| bin _time span=5m
| stats count as failed_logins by _time Account_Name src_ip
| where failed_logins >= 5
| sort -failed_logins
```

10. Detection #3 — Failed → Successful Login Correlation

Event ID 4624 represents a successful logon. Investigate whether repeated 4625 failures are followed by a relevant 4624 for the same user/source.

```
index=* (EventCode=4625 OR EventCode=4624)
| sort 0 _time
| table _time EventCode Account_Name src_ip host
```

Remember that Windows logon types and available fields vary. Validate the actual event before concluding that a successful login proves compromise.

11. Detection #4 — Suspicious PowerShell

Use Sysmon Event ID 1 to review PowerShell process creation and establish a baseline of normal activity.

```
index=* EventCode=1 Image="*powershell.exe*"
| table _time host User Image ParentImage CommandLine
```

Investigate unusual parent-child relationships, unexpected users, suspicious command lines, encoded-command usage, and related network activity. Do not treat every PowerShell event as malicious.

12. Detection #5 — Network + Process Correlation

A stronger investigation connects endpoint process telemetry with network activity. Pivot from the relevant host and timestamp into Event ID 3 network events.

```
index=* EventCode=1
(Image="*powershell.exe*" OR Image="*cmd.exe*")
| table _time host User Image ParentImage CommandLine
```

13. IOC Investigation

For a suspicious IP, domain, hash or file path, validate the IOC using trusted threat-intelligence sources and organizational context. In a portfolio lab, clearly label simulated IOCs.

- Is the IOC internal or external?
- Was the connection allowed or blocked?
- Which host, user and process generated it?
- How often did it occur?
- What happened immediately before and after it?
- Is there evidence of execution, persistence or lateral movement?
- Should the case be escalated to L2/incident response?

14. Splunk Incident Workflow

```
Alert received
↓
Triage
↓
Validate alert / remove obvious noise
↓
Gather evidence
↓
Correlate related events
↓
Classify: Benign / Suspicious / True Positive
↓
Contain or escalate according to playbook
↓
Document investigation
↓
Resolve / close when appropriate
```

Keep an active case In Progress while evidence is being gathered. Ownership and urgency should follow your organization's workflow. Resolve/close only after the investigation is complete.

15. L1 vs L2 Responsibilities

L1 SOC Analyst	L2 / Senior Analyst
Alert monitoring and triage	Deep malware/forensic analysis
Validate obvious false positives	Advanced correlation and threat hunting
Basic log correlation	Complex multi-stage attack investigation
Collect evidence and timeline	Containment/eradication decisions
Escalate according to playbook	Lead complex incident response

16. Incident Investigation Report Template

Incident: Port Scan / Failed Login / Suspicious PowerShell / Other

Date & Time: _____

Source: _____

Destination: _____

Users: _____

Processes: _____

Ports / Protocols: _____

Evidence: SPL searches, screenshots, event IDs, timestamps

Timeline: _____

Analysis: What happened and why it matters

Classification: Benign / Suspicious / True Positive / False Positive

Action: Monitor / Block / Contain / Escalate / Close

Reason: _____

17. Portfolio Deliverables

- Splunk detection SPL and screenshots
- Raw-event and investigation screenshots
- One SOC dashboard
- At least 3 incident reports
- Architecture diagram
- README/project summary
- CV-ready project description

18. Recommended Dashboard

Create panels for total events, failed logins, successful logins, top source IPs, top destination ports, PowerShell executions, network connections, and alert counts.

19. CV / Interview Description

SOC Threat Detection & Incident Investigation Lab — Splunk | Windows | Sysmon | Kali Linux

Built a controlled SOC home lab using Splunk SIEM, Windows, Sysmon, and Kali Linux to simulate and investigate security events. Developed SPL-based detections for port scanning and authentication activity, correlated Windows events, investigated endpoint/network telemetry, performed alert triage and incident classification, and documented findings using an L1 SOC investigation workflow.

20. Completion Checklist

- Kali ↔ Windows connectivity verified
- Sysmon events visible in Splunk
- Port scan generated in authorized lab
- Port scan detected
- 4625 detection tested
- 4625 → 4624 investigation completed
- PowerShell investigation completed
- Network + process pivot completed
- Benign/false-positive case documented
- Suspicious case documented

- Dashboard created
- Incident reports completed
- Portfolio screenshots collected

Next practical step

Use this guide as the project plan. Begin by recording your Windows IP, Kali IP, Splunk index, and Sysmon sourcetype. Then build Detection #1 and adapt the SPL to your actual field names.